My Experience with Bug Bounty Hunting: How I Explain It to Others

Understanding the value of independent vulnerability research and how to communicate practical experience beyond traditional employment.

Article by Marco Tavani

The Title Behind the Experience

On LinkedIn, one of the entries in my Experience section reads “Independent Cybersecurity Researcher”.

It is a relatively straightforward title, but I sometimes wonder what someone unfamiliar with my background would actually understand from it. What does being an independent cybersecurity researcher mean? What kind of activities does it involve? And, more importantly, how can I explain the practical experience behind those words to a potential employer?

I started exploring bug bounty programs in 2022, when I was 17. During the first years, I spent countless hours investigating web applications, exploring potential attack surfaces, running scans and trying to identify security weaknesses.

When I started university in September 2023, I inevitably had to reduce the time dedicated to active vulnerability research. I continued studying tools and techniques, but my participation in bug bounty programs became less frequent. Now, while pursuing my Master’s degree in Cybersecurity, I would like to dedicate more time to this activity again.

Looking back, I realize that this has been a significant part of my personal development in cybersecurity. However, describing it in a way that communicates its actual value is not always straightforward.

What Independent Research Involves

For me, bug bounty hunting has never been simply about running a scanner and waiting for a vulnerability to appear.

Over time, I have become familiar with several stages of the vulnerability research process, starting with reconnaissance and asset discovery, moving through port scanning and service enumeration, and eventually exploring web application testing and vulnerability validation.

My approach has changed considerably since I started. In the beginning, I would often approach a target by running scans and investigating whatever information came back. Gradually, I understood the importance of having a more structured approach: focusing on specific types of applications, choosing appropriate testing methodologies, and understanding what information I was actually looking for.

For example Nmap became an important part of my reconnaissance workflow, particularly through its NSE scripting capabilities, which allowed me to investigate exposed services and gather additional information. I also started experimenting with fuzzing and content discovery, using tools such as ffuf to explore applications and identify potential entry points for further investigation.

One of the biggest changes has been learning to treat automated tools as a starting point rather than a final answer. Their output can reveal interesting leads, but those findings still require investigation and manual validation.

I still rely heavily on tools, and there are areas where I want to develop considerably more confidence, including my use of Burp Suite. Nevertheless, I believe there is an important difference between someone who has only read about these tools and someone who has spent time using them to investigate real applications.

That practical familiarity, together with an understanding of the overall testing process, is something I have gradually developed through independent research.

Results, Experience and Everything In Between

Of course, vulnerability research is also about results.

Over the years, I have submitted several reports through bug bounty platforms, with a limited number of accepted findings, all classified as P5 under the respective programs' severity ratings.

However, not every interesting finding resulted in an accepted report or a reward.

On two occasions, I encountered issues with considerably higher potential impact. One involved an XSS vulnerability related to a selector being interpreted as HTML, classified as P3. The other was a denial-of-service issue affecting a company's website, classified as P1.

Both findings were acknowledged by the respective programs, but unfortunately, both submissions were closed as duplicates because the issues had already been reported by other researchers. No reward was issued.

I have also experienced submissions marked as out of scope and investigations that never resulted in a valid finding. Some of these experiences were frustrating, particularly when I was less familiar with reporting requirements and struggled to communicate my findings effectively.

Nevertheless, they taught me something important: identifying a potentially interesting behaviour is only part of the process. Understanding whether it represents a genuine security issue, demonstrating its impact, respecting the program's scope and documenting everything clearly are equally important.

I have also learned not to measure the entire experience exclusively through accepted reports or their severity ratings.

The time spent investigating an application, understanding an unfamiliar technology, experimenting with different approaches or figuring out why a particular test produced no meaningful results is also part of the learning process.

Not every investigation leads to a vulnerability, but that does not necessarily mean it was without value.

From Independent Research to Professional Value

This is probably the most interesting part of the whole experience.

When presenting my background to a potential employer, I don't want to suggest that independent vulnerability research is equivalent to working as a penetration tester within a professional security team. They are different experiences, and I believe it is important to recognize that distinction.

Working in an established environment involves additional responsibilities: interacting with clients, collaborating with colleagues, following internal procedures, managing engagements and understanding the specific requirements of an organization.

Independent research does not automatically provide that experience.

However, I believe it can demonstrate something valuable.

It shows that I have already spent considerable time approaching real-world applications from a security perspective, familiarizing myself with tools and testing methodologies, investigating potential weaknesses and learning how to validate and document findings.

It also demonstrates initiative and a willingness to develop practical skills independently, beyond what is strictly required by an academic curriculum.

These experiences are particularly relevant when considering opportunities in penetration testing, application security and vulnerability assessment, although many of the underlying skills can be useful in other cybersecurity domains as well.

I would not describe myself as an experienced security professional, but neither would I describe my background as purely theoretical.

Perhaps that is the distinction I would most like a recruiter to understand.

05

Beyond the Title

Ultimately, “Independent Cybersecurity Researcher” is just a title on a LinkedIn profile.

What matters is the work behind it: the applications investigated, the tools used, the methodologies explored, the findings submitted, the mistakes made and the knowledge acquired along the way.

I still have entire areas of cybersecurity to explore, tools to master and methodologies to improve. I also look forward to gaining experience within a professional environment, where I can learn from other people and understand how security activities are conducted beyond independent research.

For now, I see bug bounty hunting as one of the most valuable ways in which I have developed my practical understanding of cybersecurity.

It started as an attempt to learn beyond the classroom and gradually became a long-term interest that I hope to develop further throughout my academic and professional journey.

And perhaps this is ultimately how I would explain it to a recruiter: not as a substitute for professional experience, nor as a collection of impressive titles or rewards, but as evidence of a genuine, sustained effort to understand cybersecurity by putting theory into practice.